# Audit de sécurité et RGPD initial : Weekli

| | |
|---|---|
| **Projet** | Weekli (monorepo `apps/server`, `apps/web`, `apps/video`, `packages/core`) |
| **Date** | 24 octobre 2026 |
| **Auditeur** | securite-senior (audit statique, aucun code modifié) |
| **Branche auditée** | `docs/brief-v1`, commit `d40f24a` (inclut les livraisons RGPD backend et frontend faites pendant l'audit, base de départ `2a76ca2`) |
| **Périmètre** | Code (server, web, video, core, scripts, Dockerfile, docker-compose, CI), historique Git complet (18 commits, toutes les branches locales et distantes), dépôt public GitHub `Souf-F/weekli` en lecture seule, dépendances npm |
| **Cibles testées** | Fichiers locaux, historique Git local, API GitHub (lecture), bundle front compilé dans un dossier temporaire |
| **Hors périmètre** | Aucune URL de production (rien n'est déployé), aucun serveur local lancé (secrets OAuth absents) : tous les tests dynamiques sont marqués NON VÉRIFIÉ |
| **Verdict global** | **A CORRIGER** : 0 BLOQUANT, 6 MAJEUR, 17 MINEUR |

**Aucun secret réel n'a été trouvé** : ni dans le code, ni dans l'historique Git, ni sur le dépôt GitHub (secret scanning GitHub : 0 alerte).

Rappel : cet audit vérifie la conformité technique et documentaire. Il ne remplace pas l'avis d'un juriste ou d'un DPO.

## 1. Synthèse

| Sévérité | Nombre |
|---|---|
| BLOQUANT | 0 |
| MAJEUR | 6 |
| MINEUR | 17 |

Les 3 risques principaux :

1. **Le droit à l'effacement est incomplet et la page Confidentialité promet plus que le code** : le token GitHub, le nom et l'email restent stockés côté connecteur MCP (grants et Durable Objects) après « Supprimer mes données ».
2. **Les données sont rattachées au login GitHub, qui est renommable et réattribuable** : un nouveau titulaire d'un ancien login hériterait des brouillons et des domaines vérifiés de l'ancien.
3. **Une dépendance d'exécution du Worker est vulnérable** (zod 4.5.4, GHSA-mrhx-c7xc-m3w5, sévérité haute) et les polices Google Fonts transmettent l'IP des visiteurs à Google sans consentement.

Points forts constatés : PKCE S256 des deux côtés, consentement MCP par client avant GitHub (bibliothèque officielle), cookies `__Host-` `HttpOnly` `SameSite=Lax`, vérification d'`Origin` sur toutes les écritures, sessions et données chiffrées AES-256-GCM avec HKDF, CSP stricte sans script inline, validation stricte des paramètres GitHub, `global_fetch_strictly_public`, pas de shell dans les scripts vidéo, historique Git propre, secret scanning et push protection actifs sur GitHub.

## 2. Éléments sensibles trouvés

| Élément | Emplacement | Statut |
|---|---|---|
| Secret réel (clé API, token, mot de passe) | Aucun, dans le code, l'historique et GitHub | OK |
| URL avec identifiants `https://user:mdp@...` | `apps/server/src/lib/__tests__/domaines.test.ts:46` (commit `35c41ee`) | Valeur de test factice, non sensible (signalée par trufflehog, non vérifiée par lui) |
| `gho_exemple`, `sk-ant-...` | Tests et placeholder de champ | Factices |
| `.dev.vars` | Absent du disque et de tout l'historique ; seul `.dev.vars.example` (placeholders) est suivi | OK |
| Email personnel de l'auteur | Métadonnées de tous les commits publics (`sfec****`) | Donnée personnelle publique, voir m13 |
| Token GitHub de l'utilisateur final | Stocké en clair dans le stockage Durable Object du connecteur MCP (`props`) | Voir M2 |
| Clé API Anthropic de l'utilisateur | `sessionStorage` ou `localStorage` du navigateur, clé `weekli.cle` | Par conception, voir m10 |

## 3. Détail des problèmes

### MAJEUR

> **MAJEUR** **M1. apps/server/src/lib/donnees.ts:7 et apps/web/src/pages/Legal/Confidentialite.tsx:89 : effacement incomplet, promesse inexacte**

- Problème : `DELETE /api/moi/donnees` (`routes/api.ts:73`) supprime seulement `brouillons:<login>`, `domaines:<login>` et la session courante. Restent : les grants et tokens MCP de `@cloudflare/workers-oauth-provider` (props chiffrées contenant login, nom, email et token GitHub, refresh token valable 30 jours et renouvelé à chaque rafraîchissement), le stockage des Durable Objects `WeekliMCP` (voir M2), les autres sessions du même compte (autres navigateurs, jusqu'à 8 h), et le token GitHub lui-même, jamais révoqué auprès de GitHub. Or la page Confidentialité affirme : « Tout ce que Weekli détient sur toi est supprimé immédiatement : session, token GitHub, brouillons, domaines et style d'écriture ».
- Preuve : lecture de `donnees.ts` (deux `delete` KV seulement) ; `node_modules/@cloudflare/workers-oauth-provider/dist/oauth-provider.js:5084` (`DEFAULT_REFRESH_TOKEN_TTL = 720 * 60 * 60`) ; le handoff backend le reconnaît (point 2).
- Scénario : un utilisateur exerce son droit à l'effacement depuis le site, croit être effacé, mais son connecteur Claude continue de fonctionner et Weekli conserve son token GitHub et son email. Non-conformité à l'article 17 et information trompeuse (article 12).
- Correction : stocker `userId` (id GitHub numérique) dans la session ; dans `effacerDonnees`, appeler `env.OAUTH_PROVIDER.listUserGrants(userId)` puis `revokeGrant` pour chacun, purger les Durable Objects de l'utilisateur (voir M2), supprimer toutes les sessions du compte (index `sessions:<userId>` ou valeur versionnée), révoquer le token GitHub (`DELETE https://api.github.com/applications/{client_id}/grant` avec authentification basique client_id et secret). Tant que ce n'est pas fait, corriger le texte de la page Confidentialité et du panneau `PanneauDonnees.tsx`.
- Agent concerné : backend-senior (code), frontend-senior (textes).

> **MAJEUR** **M2. apps/server/src/mcp/agent.ts:30 (via agents `McpAgent.updateProps`) : token GitHub en clair et sans durée de conservation dans les Durable Objects**

- Problème : la bibliothèque `agents@0.30.0` enregistre les props de chaque session MCP dans le stockage du Durable Object (`ctx.storage.put("props", props)`, `node_modules/agents/dist/mcp/index.js:1442`). Ces props contiennent `login`, `name`, `email` et `accessToken` (token GitHub) en clair. Un Durable Object est créé par session MCP, et rien dans Weekli n'appelle `destroy()` ni `storage.deleteAll()` : les données s'accumulent sans limite de durée. Cela contredit `docs/securite.md` (« tokens chiffrés », « Fuite du stockage » protégée) et la durée de 90 jours annoncée.
- Preuve : lecture du code de la bibliothèque (lignes 1440 à 1452) ; aucune occurrence de `destroy` ou `deleteAll` dans `apps/server/src`.
- Scénario : une fuite ou un accès indu au stockage Durable Object expose directement des tokens GitHub (portée `read:user`, impact limité mais réel) et des emails ; en RGPD, conservation illimitée sans base (article 5.1.e).
- Correction : ne pas mettre le token GitHub dans les props transmises au DO, ou le chiffrer avec `chiffrer()` avant (et le déchiffrer dans le getter `octokit`) ; retirer `email` (m1) ; programmer une alarme

dans le DO (`this.schedule` ou `ctx.storage.setAlarm`) qui appelle `this.destroy()` après inactivité (par exemple 24 h ou 90 jours au maximum) ; prévoir la purge dans M1. Fixer explicitement `refreshTokenTTL` dans `OAuthProvider` (par exemple 30 jours non renouvelés) et le documenter.

- Agent concerné : backend-senior.

> **MAJEUR M3. apps/server/src/lib/brouillons.ts:7, apps/server/src/lib/domaines.ts:11 et :34 : données rattachées au login GitHub au lieu de l'id numérique**

- Problème : les clés KV (`brouillons:<login>`, `domaines:<login>`), le jeton HMAC de vérification de domaine, la limitation de débit et le `login` des outils MCP reposent sur le nom d'utilisateur GitHub. Un login GitHub peut être renommé, et l'ancien nom devient libre et réutilisable par n'importe qui. La session (`types.ts:12`) ne garde même pas l'id numérique.
- Preuve : lecture du code ; la bibliothèque OAuth, elle, indexe bien par `userId: String(user.id)` (`oauth-mcp.ts:94`), ce qui montre l'incohérence.
- Scénario : Alice (login `alice`) renomme son compte. Mallory crée un compte `alice`, se connecte à Weekli : il lit les brouillons d'Alice (contenu non publié) pendant leur durée de conservation, et hérite de ses domaines vérifiés, donc peut lancer des captures de son site au nom de Weekli. Le jeton de vérification étant dérivé du login, il est aussi identique.
- Correction : utiliser `user.id` (numérique, immuable) dans la session, les props MCP, les clés KV, le jeton HMAC et la clé de limitation de débit ; migrer les clés existantes au premier login (lire `login`, réécrire sous `id`, supprimer l'ancienne).
- Agent concerné : backend-senior (architecte pour la migration).

> **MAJEUR M4. apps/web/index.html:9 à 14 et apps/web/public/_headers:4 : Google Fonts chargées sans consentement**

- Problème : chaque page charge `fonts.googleapis.com` et `fonts.gstatic.com` dès l'affichage, ce qui transmet l'adresse IP de tout visiteur à Google (transfert hors UE) sans consentement ni nécessité technique. La page Confidentialité le mentionne (ligne 72) mais l'information ne remplace pas une base légale. Jurisprudence connue : LG München, 20 janvier 2022 (3 O 17493/20) ; la CNIL recommande l'hébergement local des polices.
- Preuve : `index.html` lignes 9 à 14 ; CSP qui autorise ces deux domaines ; bundle compilé : `https://fonts.googleapis.com` présent dans `index.html` produit.
- Scénario : plainte d'un visiteur ; la requête part avant tout choix, et aucun bandeau ne permet de la refuser.
- Correction : héberger les polices (Instrument Serif, Geist, JetBrains Mono, toutes sous licence OFL) dans `apps/web/public/fonts/` avec `@font-face`, retirer les `<link>` Google et les deux domaines de la CSP (`style-src 'self'; font-src 'self'`), puis retirer la phrase de la page Confidentialité.
- Agent concerné : frontend-senior.

> **MAJEUR M5. apps/web/src/pages/Legal/Confidentialite.tsx : information des personnes incomplète et en partie inexacte (articles 13 et 14)**

- Problème :
  - aucune base légale indiquée pour chaque traitement (contrat ou intérêt légitime pour le service, intérêt légitime pour la limitation de débit) ;

  - destinataires et sous-traitants incomplets : GitHub (identification, lecture des données), Anthropic (mode site, appelé depuis le navigateur), Cloudflare Browser Run (captures), Cloudflare Workers Logs (journaux avec erreurs, `observability.enabled: true` dans `wrangler.jsonc:37`) ; seul Cloudflare est cité ;
  - transferts hors UE (Cloudflare, GitHub, Anthropic, Google : États-Unis) sans mention du mécanisme (Data Privacy Framework ou clauses contractuelles types) ;
  - l'email GitHub collecté par le connecteur MCP (`oauth-mcp.ts:100`) n'est pas listé ; le connecteur MCP lui-même n'est pas décrit (grants, durée 30 jours) ;
  - inexactitudes : ligne 46, « le style d'écriture [est] chiffré dans Cloudflare KV » alors qu'il n'est stocké que dans le navigateur (`lib/reglages.ts:47`) ; ligne 61, « renouvelé à chaque utilisation » alors que le TTL n'est renouvelé qu'à chaque écriture ; les entrées KV écrites avant `9935891` n'ont aucun TTL ;
  - droit d'accès et de portabilité : pas d'export (seul l'affichage dans l'app) ; contact uniquement par discussion publique GitHub.
- Preuve : lecture de la page à `d40f24a` ; le handoff frontend signale lui-même les points 1 et 2.
- Scénario : information non conforme, donc traitement contestable en cas de contrôle ou de réclamation CNIL.
- Correction : ajouter un tableau finalité, données, base légale, durée, destinataires ; lister les sous-traitants et leur localisation ; corriger les deux inexactitudes ; ajouter un moyen de contact privé (adresse dédiée ou formulaire) ; prévoir un `GET /api/moi/donnees` d'export JSON (brouillons, domaines, profil). Faire relire par un juriste.
- Agent concerné : architecte (contenu), frontend-senior (page), backend-senior (export).

> MAJEUR **M6. package-lock.json : zod 4.5.4 vulnérable dans le runtime du Worker, 13 vulnérabilités npm**

- Problème : `zod@4.5.4` (dépendance directe de `@weekli/server`, de `agents` et du SDK MCP) est affecté par GHSA-mrhx-c7xc-m3w5 (sévérité haute, CVSS 8.2) : épuisement mémoire en validant un très grand tableau. Le Worker valide avec zod les entrées des outils MCP et les messages JSON-RPC envoyés par tout utilisateur authentifié (n'importe quel compte GitHub). `npm audit` : 13 vulnérabilités (2 modérées, 11 hautes) ; la CI (`npm audit --audit-level=moderate`) échouera au prochain push.
- Preuve : `npm audit`, `osv-scanner` (4 vulnérabilités dans 2 paquets : zod, undici) ; `npm ls zod`.
- Scénario : un client MCP authentifié envoie à `sauver_brouillons` un tableau de plusieurs millions d'éléments invalides ; l'isolat du Durable Object sature sa mémoire. L'exploitabilité exacte dans le runtime Workers n'a pas été testée (NON VÉRIFIÉ dynamiquement).
- Correction : passer à `zod@>=4.6.6` (et `overrides` dans le `package.json` racine si une dépendance l'épingle), mettre à jour `wrangler` (undici 7.30.1, dev seulement) ; pour `@remotion/*` (outil local uniquement), suivre le correctif amont. Relancer `npm audit`.
- Agent concerné : backend-senior.

## MINEUR

> MINEUR **m1. apps/server/src/routes/oauth-mcp.ts:100 et types.ts:7 : email collecté sans usage**

L'email GitHub est mis dans les props MCP mais n'est utilisé nulle part (minimisation, article 5.1.c). Correction : retirer `email` des `Props`. Agent : backend-senior.

> **MINEUR** **m2. apps/server/src/routes/auth.ts:68 : token GitHub non révoqué à la déconnexion**

`/auth/logout` supprime la session KV mais le token reste valide chez GitHub. Si l'app OAuth ne fait pas expirer ses tokens (NON VÉRIFIÉ : `docs/installation.md:19` parle de l'option « Expire user access tokens », que je n'ai pu confirmer pour une OAuth App), il reste valable indéfiniment. Si les tokens expirent bien en 8 h, le `refresh_token` renvoyé par GitHub est ignoré (`github-oauth.ts:55`) et le connecteur MCP (refresh 30 jours) cessera de fonctionner après 8 h. Correction : vérifier le réglage réel de l'app, révoquer à la déconnexion, et traiter le refresh GitHub ou aligner les durées. Agent : backend-senior.

> **MINEUR** **m3. apps/server/src/lib/capture.ts:44 à 68 : contournement de la preuve de propriété et SSRF résiduelle du navigateur**

Seule l'URL de la page principale est contrôlée. Une page d'un domaine vérifié peut afficher en `<iframe>` n'importe quel site public (ou toute adresse joignable par le navigateur Browser Run) ; l'image renvoyée le montre. Elle peut aussi déclencher une navigation juste après le contrôle de `location.href` (fenêtre de 200 ms avant la capture). Correction : activer `Fetch.enable` en CDP et refuser toute requête de type `Document` (cadres compris) hors domaines vérifiés ; désactiver JavaScript (`Emulation.setScriptExecutionDisabled`) après le floutage ; recontrôler l'URL après `Page.captureScreenshot`. L'accès réseau interne du navigateur Browser Run relève de Cloudflare : NON VÉRIFIÉ. Agent : backend-senior.

> **MINEUR** **m4. apps/server/src/lib/flou.ts : floutage partiel**

Ne couvre que les nœuds texte de `document.body` : valeurs des `input type=text` et `textarea`, shadow DOM, iframes, images et canvas, IPv6, numéros de téléphone, noms ne sont pas floutés ; un flou de 6 px sur du texte court peut parfois être inversé. Correction : flouter aussi `input`, `textarea`, `[contenteditable]`, parcourir les `shadowRoot`, monter le flou ou remplacer par un pavé opaque, documenter la limite. Agent : backend-senior.

> **MINEUR** **m5. apps/server/src/lib/domaines.ts:80 : domaines jamais revérifiés**

Un domaine vérifié le reste jusqu'à 90 jours sans activité, même si son propriétaire change. Correction : revérifier avant chaque capture si la preuve date de plus de 7 jours. Agent : backend-senior.

> **MINEUR** **m6. apps/server/src/mcp/agent.ts:38 : `login` figé à l'initialisation du Durable Object**

Les outils utilisent le `login` capturé dans `init()` tandis que `this.octokit` lit les props courantes. Le Durable Object est nommé d'après l'en-tête `mcp-session-id` fourni par le client (`agents/dist/mcp/index.js:107` et `:176`), sans vérification qu'il appartient au même utilisateur. Si un identifiant de session fuitait, un autre utilisateur authentifié lirait les brouillons du premier. Exploitation non testée et peu probable (identifiant aléatoire de 256 bits). Correction : lire `this.props.login` à chaque appel d'outil et refuser si l'utilisateur des props diffère de celui enregistré dans le DO. Agent : backend-senior.

> **MINEUR** **m7. packages/core/src/github.ts:72 et :101, .claude/skills/video-projet/SKILL.md : injection de prompt**

README, messages et extraits de diff sont renvoyés bruts à Claude, sans balisage indiquant un contenu non fiable, et les diffs peuvent contenir des secrets commités par l'utilisateur. Un commit tiers fusionné en squash dans un repo de l'utilisateur lui est attribué. Le skill `video-projet` se déclare utilisable « sur n'importe quel

dépôt » et fait lire README et docs à Claude Code, qui dispose d'un shell. Impact réduit côté Weekli (outils sans effet de bord hors brouillons et captures de domaines vérifiés). Correction : envelopper les contenus de repo dans un champ `contenu_non_fiable` et le rappeler dans la description des outils, masquer les motifs de secrets (ceux de `flou.ts`) dans les extraits de diff, avertir dans le skill de ne l'utiliser que sur des dépôts de confiance. Agent : backend-senior, architecte pour le skill.

> **MINEUR** **m8. apps/video/scripts/capturer.mjs:17 et :25, produire.mjs:26 et :53 : arguments non validés dans le pipeline vidéo local**

`execFileSync` sans shell : pas d'injection de commande. Mais `projet` et `nom` ne sont pas validés (`../` permet d'écrire hors du dossier prévu), et le texte de voix est passé à `say` sans `--` (un texte commençant par `-` serait lu comme option). `capturer.mjs` ouvre n'importe quelle URL, y compris locale. Outil interne, lancé par l'opérateur. Correction : valider `projet` et `nom` avec `/^[a-z0-9-]{1,40}$/`, ajouter `"--"` avant le texte de `say`. Agent : backend-senior.

> **MINEUR** **m9. apps/server/src/lib/chiffrement.ts:19 et github-oauth.ts:10 : `String.fromCharCode(...octets)` plante au-delà d'environ 125 Ko**

Preuve : `node -e` avec un `Uint8Array` de 125 000 octets : `RangeError: Maximum call stack size exceeded` (même moteur V8 que Workers). Un historique de 100 brouillons de 6 000 caractères (environ 600 Ko) ne peut plus être enregistré : déni de service sur son propre compte, erreur 502. Correction : encoder en base64 par blocs (boucle de 32 Ko) ou via `Uint8Array.prototype.toBase64` si disponible. Agent : backend-senior.

> **MINEUR** **m10. apps/web/src/lib/reglages.ts:50 : clé API Anthropic lisible par JavaScript**

Choix de conception documenté et accepté (mode bonus). La protection repose entièrement sur la CSP et sur l'intégrité des dépendances du bundle ; `connect-src https://api.anthropic.com` reste un canal d'exfiltration possible si un script étranger s'exécutait (requête faite avec la clé de l'attaquant contenant celle de la victime). Correction : garder `sessionStorage` par défaut (déjà le cas), afficher un avertissement sur l'option « mémoriser », recommander une clé dédiée avec plafond de dépense. Agent : frontend-senior.

> **MINEUR** **m11. apps/web/public/_headers et apps/server/src/lib/pages.ts:20 : en-têtes à compléter**

Pas de `Strict-Transport-Security` sur les fichiers du front (le Worker ne l'ajoute que sur ses propres réponses), pas de `Cross-Origin-Opener-Policy: same-origin` ; la page de consentement autorise `style-src 'unsafe-inline'` (sans risque pratique, tout est échappé). Correction : ajouter HSTS et COOP dans `_headers`, passer le style de la page de consentement en nonce ou en hash. Agent : frontend-senior, backend-senior.

> **MINEUR** **m12. Dépôt GitHub et outillage**

Branche `main` non protégée (`gh api .../branches/main/protection` : 404) ; alertes Dependabot et mises à jour de sécurité désactivées ; signalement privé de vulnérabilité désactivé alors que `SECURITY.md` demande de l'utiliser ; actions de CI référencées par tag et non par SHA ; aucun hook local installé dans `.git/hooks` alors que `docs/securite.md` et `SECURITY.md` l'affirment ; exclusions Git uniquement dans `.git/info/exclude` (aucun `.gitignore` partagé, choix assumé du propriétaire) ; `.dockerignore` n'exclut pas `.env*` ; images Docker de dev exécutées en root ; `dependabot.yml` sans délai de refroidissement.

Correction : activer protection de branche, Dependabot alerts et security updates, private vulnerability reporting ; installer le hook (`git config core.hooksPath` vers un dossier versionné) ; ajouter `**/.env*` à `.dockerignore`. Agent : architecte.

> **MINEUR** **m13. Historique Git public : email personnel de l'auteur visible**

Tous les commits portent l'adresse personnelle (`sfec****`), alors que les mentions légales indiquent « aucun email publié ». Correction : utiliser l'adresse `noreply` GitHub pour les prochains commits et activer « Block command line pushes that expose my email ». Sans réécriture de l'historique (contrainte du brief). Agent : architecte.

> **MINEUR** **m14. apps/server/src/lib/chiffrement.ts et domaines.ts:24 : gestion de la clé racine**

Une seule clé `COOKIE_ENCRYPTION_KEY` sert au chiffrement AES (HKDF, correct), au HMAC des domaines (dérivation ad hoc `secret:domaines`) et au consentement mémorisé ; pas de contrôle de longueur au démarrage, pas de version de clé pour une rotation, pas de données associées (AAD) liant un chiffré à sa clé KV. Correction : dériver aussi la clé HMAC par HKDF, refuser de démarrer si la clé fait moins de 32 octets, préfixer les chiffrés par une version, passer la clé KV en `additionalData`. Agent : backend-senior.

> **MINEUR** **m15. Mineurs**

Rien n'indique l'âge minimal (GitHub impose 13 ans ; la majorité numérique est de 15 ans en France). Correction : une phrase dans la page Confidentialité. Agent : frontend-senior.

> **MINEUR** **m16. apps/server/wrangler.jsonc:26 et :36 : configuration de déploiement à finaliser**

`PUBLIC_URL` vaut `http://localhost:8788` et l'id KV est un placeholder. Déployé tel quel, l'audience des tokens MCP serait fausse. Correction : à mettre dans la checklist de déploiement. Agent : architecte.

> **MINEUR** **m17. Dépendances de développement vulnérables**

`undici` (via wrangler, dev), `@remotion/*` (via zod, outil vidéo local) : sans exposition en production. Correction : mises à jour avec M6. Agent : backend-senior.

---

# 4. Checklist complète

## 4.1 Code backend

| Point | Statut | Comment |
|---|---|---|
| Injection SQL ou NoSQL | **OK** | Pas de SQL ; clés KV construites depuis la session uniquement |
| Injection de commande | **OK** | Aucune exécution de commande dans le Worker ; scripts vidéo en `execFileSync` sans shell (m8) |
| Path traversal | **OK (Worker), MINEUR (scripts locaux, m8)** | Lecture du code |
| Paramètres envoyés à l'API GitHub | **OK** | `NOM_REPO`, `SHA` validés (`validation.ts`), `owner` toujours issu du token |

| Point | Statut | Comment |
|---|---|---|
| SSRF par `fetch` du Worker | **OK** | `global_fetch_strictly_public`, HTTPS, hôte public, `redirect: manual`, 1 Ko, 5 s |
| SSRF par le navigateur Browser Run | **MINEUR (m3), NON VÉRIFIÉ dynamiquement** | Iframes et navigation tardive non contrôlées |
| Vérification de domaine (DNS TXT ou fichier, HMAC par utilisateur et domaine) | **OK, MINEUR (m5, M3)** | Lecture de `domaines.ts` et de ses tests |
| Floutage | **MINEUR (m4)** | Lecture de `flou.ts` |
| Hash des mots de passe | Sans objet | Aucun mot de passe : connexion GitHub uniquement |
| OAuth MCP : PKCE S256 vers Claude | **OK** | Bibliothèque 1.2.4, `allowPlainPKCE` retiré |
| OAuth MCP : PKCE S256 vers GitHub | **OK** | `github-oauth.ts:17`, vérifieur gardé côté serveur |
| OAuth MCP : consentement par client avant GitHub (confused deputy) | **OK** | `beginConsent`, `approveConsent`, `beginUpstream`, demande lue côté serveur |
| Page de consentement : échappement, domaine affiché, alerte loopback | **OK** | `pages.ts`, `echapper` sur toutes les valeurs du client |
| Page de consentement : CSP, nonce, `form-action`, `frame-ancestors` | **OK, MINEUR (m11)** | `pages.ts:19` |
| Audience des tokens (RFC 8707, 9728) | **OK (code), MINEUR (m16)** | `index.ts:29` |
| Enregistrement dynamique de clients | **OK** | Ouvert par conception MCP, nom marqué non vérifié |
| OAuth site : `state` 256 bits lié au cookie, usage unique, 10 min | **OK** | `auth.ts:18` à 49 |
| Redirections ouvertes | **OK** | Redirections fixes ou validées par la bibliothèque |
| Sessions : id 256 bits, nouveau à chaque connexion, contenu chiffré | **OK** | `session.ts` |
| Cookies `HttpOnly`, `Secure` (HTTPS), `SameSite=Lax`, `__Host-` | **OK** | `session.ts:26`, cookies de la bibliothèque en `__Host-oauth-` |
| Expiration des sessions | **OK (8 h), MINEUR (m2)** | Pas de révocation du token GitHub |
| Déconnexion supprime la session côté serveur | **OK** | `supprimerSession` |
| Chiffrement KV AES-256-GCM, IV aléatoire, HKDF par usage | **OK, MINEUR (m9, m14)** | `chiffrement.ts` et ses tests |
| Données MCP au repos | **MAJEUR (M2)** | Props en clair dans les Durable Objects |
| IDOR entre utilisateurs (API du site) | **OK** | Toutes les routes utilisent `session.login`, aucun id d'utilisateur en paramètre ; brouillons filtrés dans la liste du seul compte |

| Point | Statut | Comment |
|---|---|---|
| IDOR par réattribution de login | **MAJEUR (M3)** | Lecture du code |
| IDOR via identifiant de session MCP | **MINEUR (m6), NON VÉRIFIÉ** | Lecture de la bibliothèque |
| Validation des entrées (taille des corps, nettoyage des posts, storyboard) | **OK** | `bodyLimit` 64 Ko, `nettoyerPost`, `nettoyerStoryboard`, schémas zod |
| Upload de fichiers | Sans objet | Aucun upload |
| CORS | **OK** | Aucun en-tête CORS sur `/api` ; `*` sur `/mcp` (jeton porteur, sans cookie) |
| CSRF | **OK** | `SameSite=Lax` et `Origin` obligatoire et identique sur toute écriture `/api`, `/auth`, `/authorize` |
| Limitation de débit | **OK** | 20/min/IP sur l'auth, 60/min/utilisateur API et MCP, 5/min captures et vérifications ; limiteur Cloudflare approximatif et par emplacement (par conception) |
| En-têtes du Worker | **OK, MINEUR (m11)** | `securite.ts` : nosniff, XFO, HSTS, Referrer-Policy, no-store |
| Messages d'erreur génériques | **OK** | `api.onError`, `pageErreur` ; les erreurs MCP renvoient le message à Claude de l'utilisateur lui-même |
| Journaux sans donnée sensible | **OK (lecture)** | `console.error` d'erreurs Octokit (autorisation masquée par Octokit) ; NON VÉRIFIÉ sur des journaux réels |
| Tests dynamiques (requêtes forgées, autre identifiant) | *NON VÉRIFIÉ* | Aucun serveur lancé : secrets OAuth absents |

## 4.2 Base de données (Cloudflare KV et Durable Objects)

| Point | Statut | Comment |
|---|---|---|
| Base non exposée publiquement | **OK** | Services gérés Cloudflare, aucun port ; nmap sans objet (aucun hôte déployé) |
| Privilèges minimaux | **OK** | Liaisons Worker uniquement ; jetons API Cloudflare hors périmètre |
| Données sensibles chiffrées au repos | **OK (KV), KO (DO, M2)** | |
| Aucun champ interne renvoyé | **OK** | `/api/moi` ne renvoie que login, nom, avatar ; jamais de token |
| Identifiants séquentiels | **OK** | UUID v4 pour les brouillons, 256 bits pour les sessions |
| Fichiers de base ou dumps dans le dépôt | **OK** | Aucun dans `git ls-files` ni dans l'historique |
| Sauvegardes, restauration | *NON VÉRIFIÉ* | Aucune procédure documentée ; KV n'a pas de sauvegarde native |
| Row Level Security | Sans objet | Pas de Supabase |

### 4.3 Pages web côté navigateur

| Point | Statut | Comment |
|---|---|---|
| Secrets dans les bundles | **OK** | Build dans un dossier temporaire, recherche des motifs `sk-`, `pk_live`, `AKIA`, `AIza`, `ghp_`, `xox`, `eyJ` : aucun |
| URL internes dans le bundle | **OK** | Seulement des chaînes de bibliothèques (`localhost` de React Router et du SDK) |
| Source maps | **OK** | Aucun `.map` produit |
| CSP stricte, `script-src 'self'`, pas de script inline | **OK** | `_headers`, `index.html` |
| XSS : `innerHTML`, `eval`, `dangerouslySetInnerHTML` | **OK** | Aucun dans le code de l'app ; `innerHTML` dans `flou.ts` exécuté dans la page capturée, texte échappé |
| `target="_blank"` sans `noopener` | **OK** | Aucun `target="_blank"` |
| Scripts tiers et SRI | **OK** | Aucun script tiers ; seule la feuille Google Fonts (M4), sans SRI possible |
| Domaines tiers chargés | **MAJEUR (M4)** | `fonts.googleapis.com`, `fonts.gstatic.com`, `avatars.githubusercontent.com` (après connexion), `api.anthropic.com` (mode site) |
| Stockage navigateur | **MINEUR (m10)** | Clé API et préférences ; aucun cookie lisible en JS |
| Réseau, console, fichiers exposés (`/.env`, `/.git/config`...) | *NON VÉRIFIÉ* | Aucun site servi ; `run_worker_first` et le repli SPA renverraient `index.html` en 200 pour ces chemins (sans contenu sensible) |

### 4.4 Clés API

| Clé | Statut | Comment |
|---|---|---|
| `GITHUB_CLIENT_ID`, `GITHUB_CLIENT_SECRET`, `COOKIE_ENCRYPTION_KEY` | **OK** | Secrets Wrangler ou `.dev.vars` local, jamais dans le code, le bundle, le dépôt ni l'historique ; aucune variable `VITE_` |
| Token GitHub de l'utilisateur | **OK (navigateur, Claude), KO (stockage DO, M2)** | Jamais renvoyé au navigateur ni à Claude |
| Clé API Anthropic | **OK par conception, MINEUR (m10)** | Ne transite pas par le serveur (vérifié : appel direct dans `generation.ts`) |
| Droits minimaux | **OK** | Scope GitHub `read:user` |

### 4.5 Dépôt GitHub

| Point | Statut | Comment |
|---|---|---|
| Historique complet (`git log -p --all`, motifs de secrets) | **OK** | 18 commits, aucun secret |
| gitleaks | **OK** | 8.30.1 : « no leaks found » |
| trufflehog | **OK** | 3.99.4 : 1 résultat non vérifié, URL de test factice |
| Fichiers sensibles suivis ou ayant été suivis | **OK** | Seul `.dev.vars.example` |

| Point | Statut | Comment |
|---|---|---|
| `.gitignore` | **MINEUR (m12)** | Remplacé par `.git/info/exclude` local (couvre `node_modules`, `dist`, `.dev.vars`, `.env*`, `.wrangler`, sorties vidéo) |
| Visibilité | Public | `gh repo view` |
| Secret scanning et push protection | **OK** | Activés, 0 alerte |
| Dependabot alerts | **KO (m12)** | Désactivées (HTTP 403) |
| Protection de branche | **KO (m12)** | `main` non protégée |
| Branches et PR distantes | **OK** | Branches distantes déjà dans l'historique scanné ; PR #3 et #4 fermées ne touchent que des `package.json` |
| CI : permissions, déclencheurs | **OK** | `contents: read`, pas de `pull_request_target` |

### 4.6 Dépendances

| Point | Statut | Comment |
|---|---|---|
| `npm audit` | **KO (M6)** | 13 vulnérabilités, dont zod en production |
| `osv-scanner` | **KO (M6)** | zod, undici |
| `semgrep` | **OK** | 8 résultats : 2 faux positifs (`pages.ts:53`, `securite.ts:32`), 6 durcissements CI et Docker repris en m12 |

### 4.7 RGPD

| Point | Statut | Comment |
|---|---|---|
| Inventaire des données | Fait | Section 5 |
| Minimisation | **MINEUR (m1)** | Email inutile |
| Base légale | **KO (M5)** | Non indiquée |
| Cookies et traceurs avant consentement | **KO (M4)** | Aucun cookie non essentiel, aucun analytics, mais polices Google tierces |
| Bandeau | Sans objet | Pas nécessaire une fois M4 corrigé |
| Mentions légales | **OK** | Page présente (`/mentions-legales`), éditeur et hébergeur ; adresse de l'hébergeur à vérifier |
| Politique de confidentialité | **KO partiel (M5)** | Présente, incomplète |
| Politique cookies | **OK** | Section « Cookies et traceurs » |
| Droit d'accès et portabilité | **KO partiel (M5)** | Pas d'export |
| Droit à l'effacement | **KO (M1)** | Incomplet |
| Rectification, opposition | **OK partiel** | Brouillons modifiables ; demande par le dépôt public seulement |
| Formulaires et cases pré-cochées | **OK** | « Mémoriser la clé » non coché par défaut ; pas de newsletter |
| Sécurité (article 32) | **OK partiel (M2)** | HTTPS, chiffrement KV, accès restreint |
| Durées de conservation | **OK partiel (M2, M5)** | 90 jours KV, 8 h session ; DO illimité, grants 30 jours renouvelables, anciennes entrées sans TTL |

| Point | Statut | Comment |
|---|---|---|
| Transferts hors UE | **KO (M5)** | Non décrits |
| Mineurs | **MINEUR (m15)** | Non traité |

## 5. Inventaire RGPD des données personnelles

| Donnée | Où | Pourquoi | Durée | Base légale suggérée |
|---|---|---|---|---|
| Login, nom, avatar GitHub | KV `session:*` (chiffré) | Afficher le compte, appeler GitHub | 8 h | Exécution du service (contrat) |
| Token GitHub (`read:user`) | KV `session:*` (chiffré) ; grants OAuth (chiffré) ; Durable Object `props` (en clair) | Lire les repos publics | 8 h ; 30 jours renouvelables ; illimitée | Contrat |
| Email GitHub (public) | Grants OAuth et Durable Object | Aucun usage (m1) | 30 jours ; illimitée | Aucune : à supprimer |
| Id GitHub numérique, login | Index des grants OAuth (`userId`, `metadata.label`) | Lier les autorisations | Durée du grant | Contrat |
| Brouillons de posts | KV `brouillons:<login>` (chiffré) | Historique | 90 jours après la dernière écriture | Contrat |
| Domaines vérifiés et date | KV `domaines:<login>` (chiffré) | Autoriser les captures | 90 jours après la dernière écriture | Contrat |
| Consentement mémorisé par client MCP | Cookie `__Host-oauth-approvals` signé | Ne pas redemander | 30 jours | Contrat |
| Adresse IP | Limiteur de débit (mémoire Cloudflare), journaux Workers | Lutte contre les abus, diagnostic | Fenêtre de 60 s ; journaux selon la rétention Cloudflare | Intérêt légitime |
| Clé API Anthropic | Navigateur (`sessionStorage` ou `localStorage`) | Mode site | Onglet, ou jusqu'à effacement | Contrat (stockée chez l'utilisateur) |
| Style d'écriture, modèle | Navigateur (`localStorage`) | Personnaliser la génération | Jusqu'à effacement | Contrat |
| Commits et diffs envoyés à Anthropic | Transit navigateur vers Anthropic | Génération (mode site) | Selon Anthropic | Contrat, à l'initiative de l'utilisateur |
| Captures d'écran | Non stockées | Illustrer un post | Aucune | Contrat |
| Auteurs des commits (`%an`) | `apps/video/projets/<nom>/donnees.json` (local, exclu de Git) | Pub vidéo interne | Local | Intérêt légitime (outil interne) |

Sous-traitants et localisation : Cloudflare, Inc. (hébergement, KV, Durable Objects, Browser Run, journaux : États-Unis, réseau mondial) ; GitHub, Inc. (identité et données : États-Unis) ; Anthropic (mode site, appelé depuis le navigateur : États-Unis) ; Google (polices, tant que M4 n'est pas corrigé : États-Unis).

## 6. Vérifications non faites

| Vérification | Raison |
|---|---|
| Tests dynamiques de l'API, du MCP et de l'OAuth (IDOR avec un second compte, CSRF forgé, limitation de débit, en-têtes réels) | Aucun serveur lancé : secrets OAuth absents, consigne d'audit statique |
| Inspection navigateur (réseau, console, stockage, fichiers exposés) | Rien n'est servi |
| nmap | Aucun hôte déployé |
| Réseau accessible depuis Browser Run | Infrastructure Cloudflare, hors périmètre |
| Expiration réelle des tokens de l'app OAuth GitHub | Réglage de l'app sur le compte du propriétaire, non accessible |
| Exploitabilité réelle de GHSA-mrhx-c7xc-m3w5 dans Workers | Nécessite un test de charge, non autorisé |
| Sauvegardes et restauration | Aucune infrastructure |
| Règles de dépôt nécessitant `admin:repo_hook` (webhooks) | Portée du token `gh` insuffisante, sans incidence sur les secrets |

## 7. Outils utilisés

| Outil | Version | Usage |
|---|---|---|
| git | 2.50.1 | Historique complet, `git show HEAD:` |
| gitleaks | 8.30.1 | `gitleaks git --log-opts=--all --redact` |
| trufflehog | 3.99.4 | `trufflehog git file://...` |
| semgrep | 1.182.0 | `p/default`, `p/typescript`, `p/javascript`, `p/secrets`, `p/github-actions`, `p/dockerfile`, `p/nodejs` (`--config auto` refusé sans métriques) |
| osv-scanner | 2.7.0 | `scan source --lockfile package-lock.json` |
| npm audit | npm 11.16.0, Node 26.3.0 | Arbre complet |
| gh | 2.98.0 | Réglages du dépôt, alertes, branches, PR |
| Vite | 8 (projet) | Build du front dans un dossier temporaire pour inspecter le bundle |
| Google Chrome headless | Système | Conversion en PDF |

Aucun outil manquant. Pour la mise à jour de semgrep : `brew upgrade semgrep`.